

TSUMUGI タイムスタンプサービス 運用規程

1.0 版

2026年10月1日

TSUMUGI Labo.

改訂履歴

版	変更日付	変更箇所	変更内容	発行責任者
1.0	2026年10月1日	—	初版発行	TSUMUGI Labo. 渋谷 憲

目次

1. はじめに	7
1.1. 概要	7
1.2. 識別	7
1.2.1. ドキュメント名称、バージョン	7
1.2.2. オブジェクト識別子	7
1.3. 定義	8
1.3.1. 用語の定義	8
1.3.2. 本サービスの内容	8
1.3.3. タイムスタンプトークンの適用範囲	9
1.4. 本規程に関する問い合わせ先	9
2. 一般規定	9
2.1. 義務	9
2.1.1. 当方の義務	9
2.1.2. 利用者の義務	9
2.1.3. 外部サービスに関する事項	10
2.1.4. 認証局の義務	10
2.1.5. リポジトリに関する義務	10
2.2. 財務上の責任	10
2.2.1. 損害賠償責任	10
2.2.2. 免責事項	10
2.3. 解釈及び執行	11
2.3.1. 準拠法	11
2.3.2. 可分性	11
2.3.3. 存続性	11
2.3.4. 通知	11
2.3.5. 紛争解決	11
2.4. 料金	11
2.5. 公開とリポジトリ	11
2.5.1. 本サービスに関する情報の公開	11
2.5.2. 公開の頻度	11
2.5.3. アクセス制御	12

2.5.4. リポジトリ	12
2.5.5. ルート認証局証明書の識別情報	12
2.6. 機密保持	12
2.6.1. 機密扱いとする情報	12
2.6.2. 機密扱いとしない情報	12
2.6.3. 失効情報の公開	13
2.6.4. 法執行機関への情報開示	13
2.6.5. その他の理由に基づく情報開示	13
2.7. 知的財産権	13
2.8. 個人情報の取り扱い	13
3. 識別と認証	13
3.1. 初期登録	13
3.1.1. 名前の型	14
3.1.2. 名前の意味	14
3.1.3. 名前の一意性	14
3.2. 証明書発行要求の認証	14
3.3. 証明書の更新	14
3.4. 証明書の失効の申請	14
4. 運用要件	14
4.1. サービスの利用	14
4.1.1. サービスの利用申請	14
4.1.2. タイムスタンプ要求	15
4.1.3. タイムスタンプトークンの発行	15
4.1.4. タイムスタンプトークンの検証	15
4.2. サービスの一時停止	16
4.3. サービスの終了	16
4.4. 準拠性の確認	17
4.4.1. 第三者監査	17
4.4.2. 独立検証可能性による代替	17
4.4.3. 自己点検	17
4.5. アーカイブ	17
4.5.1. アーカイブの種類	17

4.5.2. アーカイブデータの保護	17
4.5.3. アーカイブデータの保管期間	17
4.6. 危殆化と災害からの復旧	18
4.6.1. 認証局の秘密鍵が危殆化した場合の対処	18
4.6.2. 利用者の計算機が不正に利用された場合の対処	18
4.6.3. 暗号アルゴリズムが危殆化した場合の対処	18
4.6.4. 災害等の発生時	18
4.7. UTC との時刻同期	19
4.8. 時刻のトレーサビリティ	19
5. 物理的及び要員的なセキュリティ管理	20
5.1. 物理的管理	20
5.1.1. ルート認証局の秘密鍵	20
5.1.2. 中間認証局の秘密鍵	20
5.1.3. TSA 秘密鍵	20
5.1.4. 設備に関する事項	20
5.2. 要員の管理	20
6. 技術的管理	20
6.1. 鍵の管理	20
6.1.1. 鍵の生成	20
6.1.2. 秘密鍵の保護	20
6.1.3. 鍵と証明書の有効期間	20
6.1.4. 鍵の更新	21
6.1.5. 鍵の廃棄	21
6.2. コンピュータセキュリティ管理	21
6.3. 証明書プロファイル	21
6.4. システムのライフサイクル管理	22
6.5. ネットワークセキュリティ	22
6.6. 暗号モジュールの技術管理	22
7. 本規程の管理	22
7.1. 本規程の変更	22
7.2. 本規程の公開と通知	22
7.3. 利用上の注意事項及び技術情報の変更	23

8. タイムスタンプトークンのプロファイル	23
---------------------------------	----

1. はじめに

TSUMUGI タイムスタンプサービス運用規程(以下「本規程」といいます。)では、TSUMUGI Labo.(以下「当方」といいます。)が提供する TSUMUGI タイムスタンプサービス(以下「本サービス」といいます。)についての基本的事項について述べます。本規程で取り扱うタイムスタンプは IETF RFC 3161「Internet X.509 Public Key Infrastructure Time-Stamp Protocol (TSP)」に準拠して発行されるものとします。

本サービスは、総務省の認定を受けた時刻認証業務ではありません。本サービスは、特定の事業者を信頼することに頼らず、誰でも確かめられる技術によって時刻を証明します。タイムスタンプトークンの時刻は情報通信研究機構(NICT)の時刻配信から取得し、発行したトークンは公開透明性ログ(Sigstore Rekord)に登録します。公開透明性ログは追記のみが可能で、過去の記録を後から差し替えられないことが暗号的に示されるため、トークンがその時刻までに存在したことを、検証者が自ら確かめることができます。本規程は、この仕組みがどのような構成で運用され、それによって何を証明できるかを開示するものです。

1.1. 概要

本規程は、当方が提供する本サービスの運用方針及び業務手続きについて記述するものです。

本規程の適用対象は本サービスのすべての利用者及び本サービスに関連する個人・法人・組織を含みます。本規程では当方、すべての利用者、及び本サービスに関連する個人・法人・組織の権利と義務を表明します。

当方は、タイムスタンプポリシー(Time-Stamp Policy)及び時刻認証局運用規程(Time-Stamping Practice Statement)をそれぞれ独立したものとせず、本規程を本サービスに関する運用方針として位置付けます。

1.2. 識別

1.2.1. ドキュメント名称、バージョン

項目	内容
ドキュメント名称	タイムスタンプサービス運用規程
バージョン	1.0 版
適用開始日	2026年10月1日
作成者	TSUMUGI Labo. 渋谷 憲

1.2.2. オブジェクト識別子

本サービスで使用するオブジェクト識別子(OID)は次のとおりです。

用途	OID
タイムスタンプポリシー	1.3.6.1.4.1.66920.1.1
存在証明添付属性(unsigned attribute)	1.3.6.1.4.1.66920.2.1

66920 は IANA が TSUMUGI Labo. に割り当てた私企業番号 (Private Enterprise Number) です。開発版が暫定弧 1.3.6.1.4.1.99999 で発行したトークンは、本規程の適用対象外とします。

1.3. 定義

1.3.1. 用語の定義

用語	定義
時刻認証局 (TSA)	RFC 3161 に準拠したタイムスタンプトークンを発行する主体。本サービスでは利用者の計算機上で動作する本ソフトウェアがこれにあたります
認証局 (CA)	TSA 証明書を発行する主体。本サービスでは当方が運営します
利用者	本ソフトウェアを導入し、本サービスの仕組みによりタイムスタンプトークンを生成する個人・法人・組織
検証者	タイムスタンプトークンの正当性を確かめる個人・法人・組織。利用者と同一とは限りません
公開透明性ログ	追記のみが可能で、過去の記録を後から差し替えられないことを暗号学的に示せる公開ログ。本サービスでは Sigstore Rekord を利用します
存在証明	公開透明性ログへの登録を示す包含証明及び署名付き checkpoint の組
witness	公開透明性ログの checkpoint に対し、第三者として連署 (cosignature) を行う主体
タイムスタンプトークン	対象データのハッシュ値と時刻を結び付け、TSA が署名した電子データ
利用上の注意事項	当方が本規程に基づき別に定める「TSUMUGI タイムスタンプサービス利用上の注意事項」。本ソフトウェアの動作、制約及び当方へ送信する情報を定めます
技術情報	リポジトリ (2.5.4) に掲載する技術情報。検証に用いる鍵及び識別子、配布物の所在、並びに運用の値を定めます

1.3.2. 本サービスの内容

本サービスは、次の三つの要素から構成されます。

- ・ 本ソフトウェア (TSUMUGI Timestamp Client) の提供。当方が開発し配布します。本ソフトウェアは利用者の計算機上で TSA として動作し、RFC 3161 に準拠したタイムスタンプトークンを生成します。TSA の署名鍵は利用者の計算機上で生成・保管され、当方はこれを保持しません。
- ・ TSA 証明書の発行 (認証局の運営)。当方はルート認証局及び中間認証局を運営し、本ソフトウェアからの証明書署名要求 (CSR) に対して TSA 証明書を発行します。これは「そのトークンがどの導入に由来するか」を示すための名乗りの裏付けであり、時刻の真正性を保証するものではありません。
- ・ 公開透明性ログへの存在証明の取得。本ソフトウェアは、タイムスタンプの生成時に対象のハッシュ値を Sigstore Rekord へ登録し、得られた包含証明と署名付き checkpoint をタイム

スタンプトークンに添付します。

本ソフトウェアは、上記のほか、タイムスタンプトークンに記録する時刻を外部の時刻配信サービスから取得します(4.7)。当該サービス、公開透明性ログ、及び witness は、いずれも当方の管理下にありません(2.1.3)。

本サービスにおいて時刻の真正性を支えるのは、上記の公開透明性ログ及びその checkpoint に連署する witness であり、当方が保持する鍵ではありません。検証者は、当方を信用することなくタイムスタンプトークンの時刻を確かめることができます。

1.3.3. タイムスタンプトークンの適用範囲

本サービスが生成するタイムスタンプトークンは、対象となる電子データが当該時刻に存在していたこと、及びその時刻以降に当該データが変更されていないことを示すために利用できます。

本規程の適用対象は、当方が配布する本ソフトウェアが 4.1.3 の手順により生成したタイムスタンプトークンに限ります。本ソフトウェアを改変した場合、当該改変版が生成したトークンは本規程の適用対象外とします。

1.4. 本規程に関する問い合わせ先

項目	内容
屋号	TSUMUGI Labo.
代表	渋谷 憲
所在地	大阪府池田市
連絡先	tsumugilabo202608@gmail.com

2. 一般規定

2.1. 義務

2.1.1. 当方の義務

当方は、次の事項について義務を負います。

- ・ 本規程に従って認証局を運営し、TSA 証明書を発行すること
- ・ ルート認証局及び中間認証局の秘密鍵を 6.1.2 に定める方法で保護すること
- ・ 失効情報(CRL)を 2.5.2 に定める頻度で更新し、リポジトリにおいて公開すること
- ・ 本ソフトウェアが生成するタイムスタンプトークンの仕様を 8 章において開示し、第三者が独立に検証できる状態を維持すること
- ・ 本規程、利用上の注意事項及びリポジトリ掲載情報を最新の状態に保つこと

当方は、個々のタイムスタンプトークンの生成には関与しません。したがって、個々のトークンに記録された時刻の正確性について当方が保証を行うことはありません。時刻の裏付けは 4.8 に定める仕組みにより成立します。

2.1.2. 利用者の義務

利用者は、次の事項について義務を負います。

- ・ 利用登録(4.1.1)にあたり、真実の情報を届け出ること
- ・ 利用上の注意事項に従って本ソフトウェアを利用すること
- ・ 本ソフトウェアを導入した計算機を適切に管理し、第三者による不正な利用を防ぐこと
- ・ 当該計算機が第三者に不正に利用されたことを認識した場合、速やかに当方へ通知すること(4.6.2)
- ・ タイムスタンプトークンを、その適用範囲(1.3.3)を超える目的に使用しないこと

2.1.3. 外部サービスに関する事項

本サービスは、Sigstore Rekor、その checkpoint に連署する witness、及び 4.7 に定める時刻配信サービスを利用します。これらは当方の管理下にありません。当方は、これらの運営主体に対して可用性・継続性に関する取り決めを有しておらず、その停止・仕様変更・終了について責任を負いません。

当方は、これらの運営に変更があり本サービスの動作に影響する場合、2.5 に定めるリポジトリにおいて告知します。

2.1.4. 認証局の義務

当方が運営する認証局は、次の事項について義務を負います。

- ・ 本規程 6.3 に定める証明書プロフィールに従って TSA 証明書を発行すること
- ・ 証明書署名要求(CSR)の署名を検証し、要求者が当該公開鍵に対応する秘密鍵を保持していることを確認すること
- ・ 失効した証明書を CRL に掲載すること
- ・ 発行した証明書のシリアル番号と公開鍵指紋の対応を記録として保持すること

2.1.5. リポジトリに関する義務

当方は、2.5.4 に定めるリポジトリを開設し、本規程、ルート認証局証明書、中間認証局証明書、失効情報、及び検証に必要な技術情報を公開します。

2.2. 財務上の責任

2.2.1. 損害賠償責任

本サービスは無償で提供します。当方は、本サービスに起因して利用者に生じた損害について、賠償の責任を負いません。ただし、当方の故意又は重大な過失による場合は、この限りではありません。

利用者が本サービスを利用したことにより第三者との間に紛争が生じた場合、利用者は自己の責任と費用によりこれを処理します。

2.2.2. 免責事項

当方は、次の事項について責任を負いません。

- ・ 本サービスが認定時刻認証業務としての効力を有しないことに起因する不利益

- ・ 公開透明性ログ、witness、その他当方の管理下でない外部サービスの停止・仕様変更・終了に起因する損害
- ・ 利用者の計算機の管理不備に起因する損害
- ・ 利用者が本ソフトウェアを改変し、又は適用範囲(1.3.3)を超えて使用したことに起因する損害
- ・ 暗号アルゴリズムの危殆化に起因して、過去に発行されたタイムスタンプトークンの証明力が低下したことによる損害

2.3. 解釈及び執行

2.3.1. 準拠法

本規程は日本法に準拠し、日本法に従って解釈されます。

2.3.2. 可分性

本規程のいずれかの条項が無効とされた場合においても、他の条項の効力は影響を受けません。

2.3.3. 存続性

2.2、2.6、2.7、及び 4.3 の規定は、本サービスの終了後も効力を有します。

2.3.4. 通知

当方から利用者への通知は、2.5.4 に定めるリポジトリへの掲載をもって行います。

2.3.5. 紛争解決

本規程又は本サービスに関して紛争が生じた場合、大阪地方裁判所を第一審の専属的合意管轄裁判所とします。

2.4. 料金

本ソフトウェアの提供及び TSA 証明書の発行は、無償で行います。利用者に課金を行うことはありません。

2.5. 公開とリポジトリ

2.5.1. 本サービスに関する情報の公開

当方は、本規程、利用上の注意事項、技術情報、認証局証明書、失効情報、証明書プロファイル、タイムスタンプトークンのプロファイル、及び検証手順をリポジトリにおいて公開します。

2.5.2. 公開の頻度

対象	頻度
本規程	改訂の都度(7.2)
利用上の注意事項及び技術情報	変更の都度(7.3)
中間認証局及びルート認証局の CRL	失効の発生時、及び有効期間が満了する前に再署名。再署名の頻度及び CRL の有効期間は技術情報に定めます
お知らせ	事象の発生の都度

2.5.3. アクセス制御

リポジトリの掲載情報は、閲覧に関する制限を設けません。掲載情報の改変は当方のみが行います。

2.5.4. リポジトリ

対象	所在
リポジトリ(本規程・利用上の注意事項・技術情報)	https://tsumugilabo.github.io/repository.html

ルート認証局証明書、中間認証局証明書及び各 CRL の所在は、技術情報に掲げます。所在を変更する場合も、変更前の所在で発行した証明書の検証に必要な配布物は、6.1.4 に定める期間、参照可能な状態に保ちます。

2.5.5. ルート認証局証明書の識別情報

検証者は、リポジトリから取得したルート認証局証明書が真正であることを、次の値により確認できます。これらの値は本規程の本文に記載するものであり、リポジトリの掲載内容とは独立に参照できます。

項目	値
主体者名	CN = TSUMUGI Labo. Timestamp Root CA
公開鍵アルゴリズム	ECDSA P-384
有効期間	2026年9月26日 01:37:53 から 2046年9月26日 01:37:53 まで(日本標準時)
証明書の SHA-256 指紋	28:2D:E5:63:C6:28:E4:10:33:04:39:43:70:95:3F:94:ED:6E:5B:D2:88:AA:F9:16:1C:F8:55:CB:07:C1:A7:36
公開鍵情報(SPKI)の SHA-256 指紋	85:EF:95:84:FF:F6:38:6F:94:35:67:0C:90:13:8A:4A:2F:D3:FC:01:F6:D8:B2:9D:F0:0E:38:BD:D3:7E:15:8A

2.6. 機密保持

2.6.1. 機密扱いとする情報

- ・ 認証局の秘密鍵及びその活性化データ
- ・ 証明書の発行記録のうち、公開鍵指紋と発行日時を除く部分
- ・ 利用者から提供を受けた連絡先情報
- ・ 登録キーの確認の記録及び押印結果の報告の記録(2.8)

2.6.2. 機密扱いとしない情報

- ・ 本規程
- ・ 認証局証明書及び失効情報
- ・ 発行済み TSA 証明書に含まれる情報
- ・ タイムスタンプトークンに含まれる情報

2.6.3. 失効情報の公開

失効した証明書のシリアル番号、失効日時、及び失効が鍵の危殆化によるものか否かの区分は、CRL により公開されます。鍵の危殆化による失効については、推定される危殆化の日時も併せて公開されます(4.6.2)。これらを超える失効の理由は公開しません。

2.6.4. 法執行機関への情報開示

当方は、法令に基づく正当な要請があった場合、機密扱いとする情報を開示することがあります。

2.6.5. その他の理由に基づく情報開示

当方は、前項のほか、利用者本人の同意がある場合に限り機密扱いとする情報を開示します。

2.7. 知的財産権

本ソフトウェアの著作権は当方に帰属します。本ソフトウェアが利用する第三者のライブラリについては、本ソフトウェアに同梱する表示に従います。

タイムスタンプトークン及び証明書に含まれる情報については、当方は権利を主張しません。

2.8. 個人情報の取り扱い

当方が利用登録(4.1.1)その他本サービスの運営に際して取得する個人情報の取扱いは、当方が別に定めるプライバシーポリシー(<https://tsumugilabo.github.io/privacy.html>)によります。

本ソフトウェア及び当方の認証局は、利用者の会社名、担当者名、電話番号及びメールアドレスを扱いません。これらが扱うのは、登録キー及びこれに対応する利用登録の識別子に限ります。

本ソフトウェアは、本サービスによるタイムスタンプの生成に際し、登録キーが有効であることを当方に確認し、また生成したタイムスタンプの結果を当方へ報告します。当方は、これらに際して受け取った情報を記録し、4.5.3 に定める期間保管します。送信する時機、及び当方が記録する項目は、利用上の注意事項に定めます。当方は、これらの記録を、不正な利用の防止、不正な利用が疑われる場合の調査、及び本サービスの利用状況の把握のために用い、2.6.4 及び 2.6.5 による場合を除き、第三者に提供しません。

本ソフトウェアは、タイムスタンプの対象となる文書の内容を当方へ送信しません。文書の内容は公開透明性ログにも登録されません。

公開透明性ログには、タイムスタンプの生成のたびに、対象データのハッシュ値、TSA 証明書の公開鍵及び当該鍵による署名が登録され、witness の連署により登録の時刻が記録されます。これらは誰でも閲覧でき、登録後に当方又はログの運営者が削除することはできません。同一の TSA 証明書により生成されたタイムスタンプは同じ公開鍵により結び付くため、第三者は、その公開鍵によるタイムスタンプの件数及び日時を知ることができます。また、対象の文書を保有する者は、当該文書についてタイムスタンプが生成されたこと及びその日時を確かめることができます。公開鍵と利用者との対応は、当方の発行記録(2.6.1)を除き公開されません。

3. 識別と認証

3.1. 初期登録

3.1.1. 名前の型

TSA 証明書の主体者名は X.501 識別名(Distinguished Name)とします。

3.1.2. 名前の意味

TSA 証明書の主体者名は、本ソフトウェアの導入ごとに割り当てられる識別子を含みます。当該識別子は利用者個人を特定するものではありません。

3.1.3. 名前の一意性

当方は、発行する TSA 証明書の主体者名が認証局内で一意となるよう管理します。

3.2. 証明書発行要求の認証

本ソフトウェアは、本サービスの利用を開始するとき(4.1.1 の同意の後)に鍵ペアを生成し、当該秘密鍵で署名した証明書署名要求(CSR)を、4.1.1 の登録キーとともに認証局へ送信します。認証局は、登録キーが有効であることを確認し、かつ CSR の署名を検証することにより、要求者が当該公開鍵に対応する秘密鍵を保持していることを確認します。

当方は、要求者の身元確認を行いません。利用登録において当方が行うのは、申込書の記載事項の確認のみです。TSA 証明書は、その導入が当方の認証局の下にあることを示すものであり、利用者の身元を証明するものではありません。

3.3. 証明書の更新

本ソフトウェアは、TSA 証明書の有効期限が接近したとき、新たな鍵ペアを生成して 3.2 と同じ手順で更新を要求します。

3.4. 証明書の失効の申請

利用者は、本ソフトウェアを導入した計算機が第三者に不正に利用されたことを認識した場合その他当該導入に係る TSA 証明書を失効させる必要が生じた場合、利用登録(4.1.1)に用いたメールアドレスから、1.4 に定める連絡先へ通知します。不正な利用が始まったと推定される日時が分かる場合は、これを併せて通知します。

当方は、当該メールアドレスが登録記録と一致することを確認した上で、当該登録キーにより発行した TSA 証明書を失効させ、CRL に掲載します。登録記録と一致しない申請については、失効を行いません。

当方は、本サービスの運営に支障を及ぼす利用を認めた場合その他必要と認める場合、利用者の申請によらず TSA 証明書を失効させることがあります。この場合、登録されたメールアドレスへ通知します。

4. 運用要件

4.1. サービスの利用

4.1.1. サービスの利用申請

本サービスの利用にあたり、利用登録を要します。利用者は、当方所定の申込書により、メール又は書面で利用を申し込みます。当方は、申込みの内容を確認した上で、登録キーを申込書に記載

されたメールアドレスへ送付します。利用者が希望する場合は、書面によっても送付します。

本ソフトウェアは、本サービスの利用を開始する際に本規程への同意を求めます。同意しない場合、本ソフトウェアは TSA 証明書を取得せず、本サービスによるタイムスタンプを生成しません。

本ソフトウェアが備えるその他の機能、すなわち利用者が別途利用する時刻認証局によるタイムスタンプの付与、及びタイムスタンプの検証は、本規程の対象ではありません。利用者が別途利用する時刻認証局によるタイムスタンプの付与は、利用登録を要しません。タイムスタンプの検証は、利用登録及び本規程への同意の有無にかかわらず、誰でも利用できます。

本ソフトウェアは、同意した本規程の版及び日時を利用者の計算機に記録し、証明書署名要求に際して同意した版を当方へ送信します。当方はこれを発行記録に記録します(4.5.1)。

当方は、1 の利用登録につき発行する TSA 証明書の数に上限を設けます。上限の値は、リポゾトリの技術情報(利用登録の項)において公開します。

当方は、本サービスの運営に支障を及ぼす利用を認めた場合、当該利用登録に係る登録キーを無効とすることがあります。

4.1.2. タイムスタンプ要求

本ソフトウェアは、利用者の操作に応じて対象データのハッシュ値を算出し、タイムスタンプの生成処理を開始します。ハッシュ値の算出は利用者の計算機上で行われ、対象データそのものが計算機外へ送信されることはありません。

4.1.3. タイムスタンプトークンの発行

本ソフトウェアは、次の手順によりタイムスタンプトークンを生成します。

- ・ 4.7 に定める時刻配信サービスへ問い合わせ、日本標準時を取得する
- ・ 取得した時刻を記録した RFC 3161 タイムスタンプトークンを、TSA 秘密鍵により署名して生成する
- ・ 対象データのハッシュ値に TSA 秘密鍵による署名を付して Sigstore Rekord へ登録し、包含証明及び署名付き checkpoint を取得する
- ・ トークンに記録した時刻と、checkpoint に含まれる witness の連署が示す時刻とを照合する
- ・ 取得した存在証明を、トークンの unsigned attribute(TSA の署名の対象外の領域)へ格納する
- ・ 当該トークンを、対象の PDF へ埋め込み、又は分離トークンとして出力する

存在証明は TSA の署名の対象外に格納されます。その正しさは、TSA 秘密鍵ではなく、公開透明性ログの鍵及び witness の連署により確かめられます(4.1.4 第四項から第六項)。

時刻の取得若しくは存在証明の取得に失敗した場合、又は前記の照合において許容範囲を超える差を認めた場合、本ソフトウェアはタイムスタンプトークンを生成しません。時刻の裏付けを欠いたトークンを生成しないための措置です。

4.1.4. タイムスタンプトークンの検証

検証者は、次の事項を確認することによりタイムスタンプトークンを検証します。手順の詳細はリポジトリにおいて公開します。

- ・ 第一項: 存在証明が unsigned attribute(1.2.2)として添付されていること
- ・ 第二項: TSA 証明書が当方のルート認証局(2.5.5)に連なり、失効していないこと。失効している場合は、第六項の witness の連署が示す時刻が 4.6.2 に定める基準日時より前であること。失効の有無は、検証の時点でリポジトリに公開されている最新の CRL により確認すること
- ・ 第三項: タイムスタンプトークンの署名が有効であること
- ・ 第四項: 添付された包含証明が、checkpoint の root hash と整合すること
- ・ 第五項: checkpoint が公開透明性ログの鍵により署名され、かつ当方がリポジトリに掲げる witness の連署が有効であること
- ・ 第六項: トークンに記録された時刻が、witness の連署が示す時刻と矛盾しないこと

第一項を欠くトークンは、本規程に適合するものではありません。4.8 に述べる時刻の裏付けは、第一項を確認することを前提として成立します。存在証明が添付されていないトークンについては、記録された時刻の裏付けは存在しません。検証者は、そのようなトークンを本規程に適合するものとして扱ってはなりません。

第四項から第六項は、当方の関与なく検証できます。検証に必要な鍵及び識別子はリポジトリにおいて公開します。

4.2. サービスの一時停止

当方は、保守その他の理由により、当方のサーバを一時停止することがあります。計画的に停止する場合は、事前にリポジトリにおいて告知します。

本ソフトウェアによるタイムスタンプの生成は、当方のサーバ、公開透明性ログ及び 4.7 に定める時刻配信サービスへ到達できることを要します(2.1.3、2.8)。タイムスタンプの検証は、当方のサーバが停止している間も行えます。これらに到達できない間の本ソフトウェアの動作は、利用上の注意事項に定めます。

4.3. サービスの終了

当方が本サービスを終了する場合、終了の 3 か月前までにリポジトリにおいて告知します。告知の後、新規の TSA 証明書の発行を停止します。

本サービスの終了後においても、公開透明性ログに登録された存在証明は当方の関与なく検証できます。当方は、終了後においても、ルート認証局証明書、中間認証局証明書、及び最終の失効情報を、発行済みの TSA 証明書がすべて有効期間を満了した後 1 年を経過するまでの間(終了の告知から最長 3 年間)、リポジトリにおいて参照可能な状態に保ちます。

リポジトリの公開を終えた後は、最新の CRL を取得できないため、本ソフトウェアによる検証は、失効の有無を確認できない旨の警告を伴う結果となります(利用上の注意事項)。この場合においても、公開透明性ログに登録された存在証明は、4.1.4 第四項から第六項により引き続き確かめられます。また、PDF にタイムスタンプの生成時の検証材料(証明書及び CRL)が埋め込まれている場合は、これにより生成の時点で TSA 証明書が失効していなかったことを確かめられます。

4.4. 準拠性の確認

4.4.1. 第三者監査

本サービスは、第三者機関による準拠性監査を受けていません。

4.4.2. 独立検証可能性による代替

当方は、第三者監査に代えて、タイムスタンプトークンの時刻が当方の関与なく検証できる状態を維持することにより、本サービスの主張の妥当性を担保します。このために必要な仕様・鍵・識別子はすべてリポジトリにおいて公開します(4.1.4)。

4.4.3. 自己点検

当方は、失効情報の更新状況及びリポジトリ掲載情報の到達性について自動の点検を、認証局の設定及び証明書の発行記録について代表者による確認を、それぞれ定期的に行います。点検の項目及び頻度は技術情報に定めます。

ルート認証局 CRL の有効期間の満了が近づいた場合、点検はその旨を代表者へ通知します。ルート認証局 CRL の再署名は、ルート秘密鍵を保管するオフライン環境において代表者が行います(5.1.1)。

点検により不備を認めた場合、当方は速やかに是正し、利用者に影響が及ぶものについてはリポジトリにおいて告知します。

4.5. アーカイブ

4.5.1. アーカイブの種類

当方は、次の記録を保存します。

- ・ 証明書の発行記録(シリアル番号、公開鍵指紋、発行日時、同意した本規程の版)
- ・ 失効記録(シリアル番号、失効日時)
- ・ 登録キーの確認の記録(2.8)
- ・ 押印結果の報告の記録(2.8)
- ・ 認証局の設定変更の記録
- ・ 本規程の各版

4.5.2. アーカイブデータの保護

アーカイブデータは、当方のみが変更できる領域に保存します。

4.5.3. アーカイブデータの保管期間

アーカイブデータは、次の期間保管します。

対象	保管期間
証明書の発行記録及び失効記録	当該証明書の有効期限の到来から 7 年
登録キーの確認の記録	当該確認の日から 3 年
押印結果の報告の記録	当方が報告を受け取った日から 3 年
認証局の設定変更の記録	当該変更の日から 7 年

対象	保管期間
本規程の各版	7.2 に定めるとおり(削除しません)

4.6. 危殆化と災害からの復旧

4.6.1. 認証局の秘密鍵が危殆化した場合の対処

中間認証局の秘密鍵が危殆化した場合、当方は当該中間認証局証明書を失効させ、リポジトリにおいて告知します。

中間認証局の秘密鍵を喪失した場合、当方はその旨及び本サービスへの影響をリポジトリにおいて告知します。

ルート認証局の秘密鍵が危殆化した場合、当方は本サービスを停止し、リポジトリにおいて告知します。

いずれの場合においても、公開透明性ログに登録済みの存在証明は影響を受けません。認証局の危殆化は、名乗りの裏付けを失わせるものであり、時刻の真正性を失わせるものではありません(1.3.2)。

4.6.2. 利用者の計算機が不正に利用された場合の対処

利用者は、本ソフトウェアを導入した計算機が第三者に不正に利用されたことを認識した場合、3.4 に従って当方へ通知します。当方は当該証明書を、鍵の危殆化を理由として失効させます。

この場合、当方は推定される危殆化の日時を CRL に記載します。利用者から推定日時の通知があればその日時を、なければ通知を受け付けた日時を用います。以下、この日時を基準日時といい、危殆化以外の理由による失効では失効日時を基準日時とします。

失効した TSA 証明書によるタイムスタンプトークンのうち、witness の連署が示す時刻が基準日時より前であるものは、4.1.4 の検証において引き続き有効と判定されます。当該トークンが基準日時より前に正当な鍵の保持者によって生成されたことは、公開透明性ログの記録により確かめられるためです(4.8)。基準日時以降のもの、及び witness の連署により時刻を確定できないものは、無効と判定されます。

RFC 3161 は、鍵の危殆化により失効した TSA 証明書によるトークンをすべて信用しないものとしています。本項の扱いはこれと異なります。本サービスでは時刻の裏付けを TSA 秘密鍵ではなく公開透明性ログに置くためです(4.8)。RFC 3161 に従う汎用の検証ソフトウェアは、当該証明書によるトークンをすべて無効と表示することがあります。

失効の対象は当該利用登録に係る TSA 証明書に限られ、他の利用者の TSA 証明書及びトークンには影響しません。

4.6.3. 暗号アルゴリズムが危殆化した場合の対処

当方は、本サービスが使用する暗号アルゴリズムの安全性に懸念が生じた場合、リポジトリにおいて告知し、アルゴリズムの移行を検討します。

4.6.4. 災害等の発生時

当方の認証局は、複数の拠点に分散して稼働するクラウド実行基盤(5.1.4)上で運用されており、単一施設の障害による影響を受けにくい構成です。ルート認証局の秘密鍵はオフラインで保管します(5.1)。

4.7. UTC との時刻同期

本ソフトウェアがタイムスタンプトークンに記録する時刻は、日本標準時を配信する公的機関の時刻配信サービスから取得した時刻に基づきます。本ソフトウェアは、タイムスタンプの生成のたびに当該サービスへ問い合わせ、得られた時刻を用います。利用者の計算機の時計は用いません。配信元、取得の方式、及び照合の許容差は技術情報に定めます。

利用者の計算機から当該サービスへ到達できない場合、本ソフトウェアはタイムスタンプを生成しません(4.1.3)。通信の要件は利用上の注意事項に定めます。

当該サービスから取得した時刻それ自体は、時刻の裏付けとはなりません(6.5)。裏付けは、次項に定める照合により与えられます。

本サービスにおいて時刻の裏付けを与えるのは、4.8 に定める公開透明性ログ及び witness の連署です。本ソフトウェアは、記録しようとする時刻を当該連署が示す時刻と照合し、許容範囲を超える差がある場合はタイムスタンプを生成しません。検証者は、同じ照合を当方の関与なく行うことができます(4.1.4)。

4.8. 時刻のトレーサビリティ

本サービスは、認定を受けた時刻配信事業者による時刻監査証を用いません。これに代えて、次の仕組みにより時刻の裏付けを与えます。

- ・ タイムスタンプの生成時に、対象データのハッシュ値を公開透明性ログ(Sigstore Rekord)へ登録する
- ・ 当該ログは追記のみが可能であり、過去の位置に後から記録を差し込むことができない
- ・ ログが発行する checkpoint に対し、第三者である witness が連署する。当該連署は署名された時刻を含む
- ・ タイムスタンプトークンには、包含証明・checkpoint・witness の連署が添付される

これにより、存在証明が添付されたタイムスタンプトークンについては、記録された時刻より後に当該トークンを作成することができません。過去の時刻を名乗るトークンを作成したとしても、公開透明性ログに残る記録との間に矛盾が生じ、4.1.4 の手順により検出されます。

本項の主張は、検証者が 4.1.4 第一項を確認することを前提とします。存在証明が添付されていないトークンは、TSA 秘密鍵さえあれば任意の時刻を名乗って作成できるため、本項の対象外です(4.1.4)。

当方が信頼対象とする witness は、当方が技術情報に掲げるものに限ります。各 witness の運用の状況(試験運用か否か等)も技術情報に記載します。当方は、信頼対象とする witness を加える場合、リポジトリにおいて告知します。信頼対象から外した witness の公開鍵も、それ以前に生成されたタイムスタンプトークンの検証のため、引き続き公開します。公開透明性ログの識別子、ログの公開鍵、信頼対象とする witness の名称及び公開鍵、並びに checkpoint の署名対象仕様は、リポジトリにおいて公開します。

5. 物理的及び要員のセキュリティ管理

本章では、本サービスの構成において実際に講じている措置を記載します。

5.1. 物理的管理

5.1.1. ルート認証局の秘密鍵

ルート認証局の秘密鍵は、ネットワークに接続しない環境において生成し、オフラインで保管します。中間認証局証明書への署名を行う場合を除き、使用しません。

5.1.2. 中間認証局の秘密鍵

中間認証局の秘密鍵は、認証局の実行基盤(5.1.4)が提供する秘密情報の保管機能に保管します。当該鍵はソースコード及び公開領域には配置しません。

5.1.3. TSA 秘密鍵

TSA 秘密鍵は、利用者の計算機上で生成され、Windows DPAPI により当該利用者のアカウントに紐付けて保護された状態で保管されます。当方はこれを保持しません。

5.1.4. 設備に関する事項

認証局の実行環境は、外部の事業者が提供するクラウド実行基盤に依拠します。当該事業者及び基盤の名称は技術情報に掲げます。

5.2. 要員の管理

認証局の運用は代表者が行います。代表者は、電子認証局の運用管理及び運用規程の策定に関する実務経験を有します。

6. 技術的管理

6.1. 鍵の管理

6.1.1. 鍵の生成

鍵	アルゴリズム	生成場所
ルート認証局	ECDSA P-384	オフライン環境
中間認証局	ECDSA P-384	オフライン環境
TSA	ECDSA P-256	利用者の計算機

6.1.2. 秘密鍵の保護

5.1 に定めるとおりとします。

6.1.3. 鍵と証明書の有効期間

証明書	有効期間
ルート認証局	20 年
中間認証局	10 年

証明書	有効期間
TSA	2 年

6.1.4. 鍵の更新

TSA 証明書の更新に際しては、新たな鍵ペアを生成します(3.3)。

当方が認証局を更改する場合においても、旧認証局の証明書及び最終の失効情報は、当該認証局が発行した TSA 証明書がすべて有効期間を満了した後 1 年を経過するまでの間、リポジトリにおいて参照可能な状態に保ちます。既に発行されたタイムスタンプトークンの検証可能性を維持するためです(4.3、7.2)。

6.1.5. 鍵の廃棄

有効期間の満了又は失効により使用しなくなった秘密鍵は、復元できない方法で消去します。

6.2. コンピュータセキュリティ管理

認証局の実行環境はクラウド実行基盤(5.1.4)です。証明書の発行に用いるコードは当方が管理する版のみを配備します。

証明書発行要求の受付にあたり、要求者の身元確認は行いません(3.2)。要求には 4.1.1 の登録キーを要し、当方は登録キーごとに発行数の上限を設けます。上限を超える要求及び登録キーを伴わない要求は、受け付けません。

6.3. 証明書プロファイル

当方が発行する証明書は、次のプロファイルによります。証明書署名要求が要求した拡張は、これを採用しません。

項目	ルート認証局	中間認証局	TSA
版	X.509 v3	X.509 v3	X.509 v3
主体者名	CN = TSUMUGI Labo. Timestamp Root CA	CN = TSUMUGI Labo. Timestamp Issuing CA 1	導入ごとの識別子(3.1.2)
公開鍵	ECDSA P-384	ECDSA P-384	ECDSA P-256
署名アルゴリズム	ECDSA with SHA-384	ECDSA with SHA-384	ECDSA with SHA-384
basicConstraints	critical, CA:TRUE	critical, CA:TRUE, pathlen:0	critical, CA:FALSE
keyUsage	critical, keyCertSign, cRLSign	critical, keyCertSign, cRLSign	critical, digitalSignature
extendedKeyUsage	—	—	critical, id-kp-timeStamping のみ
CRL 配布点	—	ルート認証局 CRL(2.5.4)	中間認証局 CRL(2.5.4)

項目	ルート認証局	中間認証局	TSA
認証局情報アクセス	—	ルート認証局証明書(2.5.4)	中間認証局証明書(2.5.4)
主体者鍵識別子・認証局鍵識別子	あり	あり	あり
有効期間	6.1.3 のとおり	6.1.3 のとおり	6.1.3 のとおり

失効情報は X.509 v2 CRL とし、ECDSA with SHA-384 により署名します。失効した証明書のエントリーは、当該証明書の有効期間が満了した後も CRL から削除しません。有効期間の満了後に行われる検証においても、失効の有無及び基準日時(4.6.2)を確かめられるようにするためです。

6.4. システムのライフサイクル管理

本ソフトウェア及び認証局のコードは、当方が版管理のもとで開発し、変更の履歴を保持します。

6.5. ネットワークセキュリティ

証明書の発行、失効情報の配布、及び公開透明性ログとの通信は、TLS により保護された経路で行います。

4.7 に定める時刻配信サービスとの通信は、経路の認証を伴わないことがあります。このため、本ソフトウェアは当該サービスから取得した時刻を単独では用いず、witness の連署との照合を経たうえでタイムスタンプを生成します(4.7)。

6.6. 暗号モジュールの技術管理

本サービスは、ハードウェアセキュリティモジュール(HSM)を使用しません。

これは、本サービスにおいて TSA 秘密鍵が時刻の真正性の根拠ではないこと(1.3.2、4.8)に基づく判断です。

ただし、この判断は検証者が 4.1.4 の手順を行うことを前提とします。とりわけ第一項(存在証明の添付)を確認しない場合、TSA 秘密鍵が漏洩すれば任意の時刻を名乗るトークンを作成できます。第一項及び第五項・第六項を確認して初めて、TSA 秘密鍵の漏洩により生じるのは名乗りの詐称にとどまり、過去の時刻の偽造には及びません。

7. 本規程の管理

7.1. 本規程の変更

当方は、本サービスの運用の変更、法令の改正、その他の理由により、本規程を変更することがあります。

7.2. 本規程の公開と通知

当方は、本規程を変更した場合、変更後の版をリポジトリにおいて公開します。過去の版は削除せず、併せて公開します。過去に発行されたタイムスタンプトークンの検証には、当該トークンの発行

時点において適用されていた版が必要となるためです。

当方は、本規程を変更した場合、利用登録(4.1.1)に用いられたメールアドレスへその旨を通知します。利用者が通知の後に本サービスを利用したときは、変更後の本規程に同意したものとみなします。本ソフトウェアは、本規程の変更の都度改めて同意を求めることはしません。

7.3. 利用上の注意事項及び技術情報の変更

当方は、本サービスの運用に応じて、利用上の注意事項及び技術情報を変更することがあります。変更は、本規程の変更によらず行います。ただし、本規程に定める事項に反する変更は行いません。

当方は、利用上の注意事項を変更した場合、変更後の版をリポジトリにおいて公開し、過去の版も併せて公開します。また、利用登録(4.1.1)に用いられたメールアドレスへその旨を通知します。利用者が通知の後に本サービスを利用したときは、変更後の利用上の注意事項に同意したものとみなします。

当方は、技術情報を変更した場合、リポジトリのお知らせにおいて告知します。検証に用いる鍵及び識別子は、追記のみとし、それ以前に生成されたタイムスタンプトークンの検証のため、削除しません。

8. タイムスタンプトークンのプロファイル

本サービスが生成するタイムスタンプトークンの主要な項目は次のとおりです。

項目	内容
規格	RFC 3161
ハッシュアルゴリズム	SHA-256
署名アルゴリズム	ECDSA with SHA-256(P-256)
ポリシー OID	1.3.6.1.4.1.66920.1.1
存在証明の格納場所	unsigned attribute(1.3.6.1.4.1.66920.2.1)
証明書の同梱	TSA 証明書及び中間認証局証明書を含む。ルート認証局証明書は含まない(2.5.5 により確認する)

存在証明として格納される内容は次のとおりです。

項目	内容
包含証明	RFC 6962 に準拠した Merkle 包含証明
checkpoint	公開透明性ログが署名した署名付きツリーヘッド
witness 連署	checkpoint に対する第三者の連署(署名時刻を含む)

各項目の符号化の詳細、及び検証に必要な鍵の値はリポジトリにおいて公開します。